Лабораторная работа 14. Документация, безопасность и ответственное применение ML

Версия: 2026–2027 учебный год

Формат: команда 2–5 человек с индивидуальной сдачей

Продолжительность: 2 академических часа и самостоятельная работа

Предшествующая работа: ЛР13 «Point-in-time признаки и Feature Store»

1. Цель

Подготовить проверяемый комплект evidence ответственного учебного выпуска: model/data cards, групповые метрики, policy, threat model, security и license review; принять обоснованное решение.

2. Результаты обучения

Каждый студент должен уметь:

• связать документацию с точной версией системы;

• объяснить intended use и out-of-scope;

• рассчитать общие и групповые метрики;

• корректно обработать малую группу;

• интерпретировать gap без заявления о доказанной fairness;

• проследить угрозу от актива до контроля и residual risk;

• объяснить rotation секрета и allowlist логов;

• защитить собственное решение release/review/stop.

3. Командный результат

Команда предоставляет tag `lr14-v1`:

1. заполненные `docs/model-card.md` и `docs/data-card.md`;
2. version-controlled `governance/responsible_ai_policy.json`;
3. воспроизводимый `reports/governance/lr14-report.json`;
4. `docs/security/threat-model.md` и `SECURITY.md`;
5. реестр/процесс проверки лицензий;
6. responsible-use checklist;
7. минимум четыре теста и CI gate;
8. issue, PR, review и отдельная evidence card каждого участника.

4. Безопасная область работы

Используйте только синтетические данные курса. Не добавляйте реальные персональные, чувствительные или закрытые атрибуты. `IsWeekend` выбран как безопасный учебный сегмент для механики группового аудита и не считается защищённым признаком.

5. Подготовка

```
python -m pip install -e ".[dev]"
python -m pytest tests/test_governance.py -q
```

Проверьте, что файлы ЛР13 и предыдущие CI gates не повреждены.

6. Базовый запуск

```
python -m mlops_flight_delay.governance \
  --evaluation data/governance/evaluation.csv \
  --policy governance/responsible_ai_policy.json \
  --model-card docs/model-card.md \
  --output reports/governance/lr14-team-baseline.json
```

Ожидаются status `pass`, две опубликованные группы, полный model card и допустимый F1 gap.

7. Policy as code

Policy фиксирует версию, group column, classification threshold, minimum group rows, общий минимум

F1, максимум F1 gap, обязательные разделы карточки и запрещённые поля логов. Изменение policy проходит

отдельный PR; нельзя подгонять порог после просмотра результата без объяснения.

8. Model card

Замените учебные placeholders фактическими именами команды, registry version, commit SHA, периодом оценки и release decision. Каждое утверждение о качестве должно ссылаться на воспроизводимый отчёт.

9. Intended use

Укажите пользователя, момент прогноза, допустимое действие, данные и масштаб. Недопустимые сценарии перечислите явно. Формулировка «для аналитики» без границ не принимается.

10. Data card

Проверьте происхождение, состав, target, временное разбиение, качество, права, срок хранения, удаление и ограничения. Внешний набор без подтверждённых условий использования не допускается.

11. Evaluation dataset

Файл содержит `request_id`, `y_true`, `prediction_probability` и `IsWeekend`. Реальный проект должен фиксировать временное окно и связь с model version; учебный sample служит только для теста механики.

12. Общие метрики

Отчёт содержит rows, positive rate, predicted positive rate, precision, recall, F1 и ROC AUC. ROC AUC не вычисляется для группы с одним классом и сохраняется как `null`, а не придуманное значение.

13. Групповые метрики

Метрики считаются тем же кодом и threshold для каждой достаточной группы. Сохраняйте n: сравнение без объёма выборки не проходит защиту. Объясните различие base rate и predicted positive rate.

14. Minimum support

Создайте личный сценарий, в котором одна группа меньше policy minimum. Ожидается `insufficient_sample`, отсутствие метрик этой группы и общий status `review`. Не дублируйте строки ради прохождения gate.

15. F1 gap

Gap — разница максимального и минимального F1 среди достаточных групп. Он полезен как сигнал, но не является универсальной fairness-метрикой. Интерпретация включает n, base rate, другие ошибки и контекст использования.

16. Threshold experiment

Каждый участник либо команда выполняет контролируемое изменение threshold в отдельной policy-копии. Сравните precision, recall, predicted positive rate и gap. Не изменяйте baseline policy молча.

17. Completeness audit

Модуль извлекает H2/H3 headings и проверяет обязательные разделы model card. Удалите один heading в личной ветке: CI должен получить `review`/ненулевой exit. Наличие heading не заменяет review текста.

18. Threat model

Опишите активы, границы доверия и минимум пять угроз. Для каждой укажите последствие, preventive или detective control, владельца и остаточный риск. Хотя бы одна угроза относится к ML: poisoning, leakage, model substitution или неверная версия признаков.

19. Secret incident drill

Не создавая настоящего секрета, используйте строку `DEMO_REVOKED_TOKEN` в локальном fixture, который не commitится. Опишите порядок: остановить использование, отозвать/ротировать, оценить охват, исправить источник, очистить артефакты, задокументировать. Не помещайте значение в evidence.

20. Логи и privacy

Сверьте API/observability с `prohibited_log_fields`. Докажите, что логи содержат технические поля, но не raw features, token, password или personal data. Скриншот одного запроса недостаточен — нужен тест или поиск по воспроизводимому журналу.

21. Зависимости и лицензии

Получите список фактических runtime dependencies/SBOM разрешённым инструментом. Для выбранного компонента проверьте точную версию и лицензию по официальному источнику. Не копируйте случайную таблицу из Интернета и не делайте юридических заключений.

22. Release decision

Команда выбирает `release`, `review` или `stop`. Решение содержит дату, model/data version, policy, результат gates, известные ограничения, владельца, reviewer, mitigation и rollback trigger.

23. Автоматические тесты

Обязательны проверки:

1. общие и групповые метрики формируются;
2. F1 gap сравнивается с policy;
3. малая группа получает `insufficient_sample`;
4. отсутствующий heading обнаруживается;
5. неверные probabilities/labels отклоняются;
6. отчёт содержит предупреждение, что сегмент не доказывает fairness.

24. CI

Workflow запускает governance CLI после тестов и PIT-аудита, а JSON попадает в diagnostic artifacts. Неполный model card или нарушенный policy возвращает ненулевой exit. Любое исключение оформляется

как явное решение преподавателя, а не `continue-on-error`.

25. Командные роли

Для команды 2–5 человек:

• владелец model card и release context;

• владелец data card/provenance/retention;

• владелец grouped metrics и policy;

• владелец threat model/security drill;

• владелец dependency/license evidence и CI.

В паре роли совмещаются. Роли должны отличаться от ЛР13; общий файл не отменяет личного артефакта.

26. Индивидуальная сдача участника команды

Командный результат: tag `lr14-v1`, cards, policy, audit, threat model, security/license evidence.

Каждый участник заполняет `docs/evidence/lr14-evidence-card.md`. Совпадающие карточки не принимаются.

Поле	Что указать
Студент	ФИО, группа, команда и GitHub-логин
Лабораторная	ЛР14, tag и commit SHA
Роль	роль и отличие от ЛР13
Задача	собственная issue и критерий приёмки
Личный артефакт	section, policy, test, threat/control, license record или CI gate
Запуск	личный сценарий и отдельный output
Evidence	n, метрики, gap, completeness и статус
Решение	release/review/stop, альтернатива и residual risk
Review	ссылка на содержательный review другого участника
Использование ИИ	инструмент и самостоятельно проверенные утверждения

27. Минимальный допуск

1. Командная версия отмечена tag и commit SHA.

2. Есть собственная issue с наблюдаемым критерием.

3. Личный артефакт встроен в командную версию.

4. Изменение прошло PR и review другого участника.

5. Личный сценарий воспроизводится отдельной командой.

6. CI успешен либо исключение письменно принято преподавателем.

7. Студент объясняет ограничение своего evidence.

28. Индивидуальная защита

За 3–4 минуты участник:

1. показывает личный артефакт в tag;

2. воспроизводит свой negative/edge scenario;

3. интерпретирует n, метрики и status;

4. изменяет threshold или minimum support по заданию;

5. объясняет, почему результат не доказывает fairness;

6. прослеживает угрозу до контроля и residual risk;

7. называет условие остановки/rollback и владельца.

29. Повторная сдача и стоп-факторы

Повторная сдача: переоткрытая issue, отдельный PR, новый JSON и обновлённая evidence card. История первой попытки сохраняется.

Стоп-факторы:

• реальные чувствительные данные добавлены в репозиторий;

• секрет опубликован или показан в evidence;

• малые группы интерпретируются как надёжные;

• один gap назван доказательством fairness;

• model/data card не соответствует версии артефакта;

• лицензия придумана без проверки источника;

• security checklist заменяет threat model;

• CI gate отключён ради зелёного статуса;

• общий отчёт выдан за индивидуальный вклад;

• студент не может объяснить решение.

30. Критерии оценивания

Критерий	Баллы	Полное выполнение
Model/data cards и provenance	2	назначение, версии, права и ограничения проверяемы
Групповые метрики и policy	2	n, threshold, minimum support и gap корректны
Security и threat model	2	активы, границы, controls и residual risk связаны
Тесты, CI и release decision	2	gates воспроизводимы, решение имеет владельца
Индивидуальный вклад и защита	2	личный сценарий, evidence, review и объяснение

Максимум: 10 баллов. Порог зачёта — 6 баллов при отсутствии стоп-факторов.

31. Чек-лист

• [ ] Команда 2–5 человек, роли ротированы.

• [ ] Model card связан с model/data/commit versions.

• [ ] Intended use и out-of-scope конкретны.

• [ ] Data card содержит provenance, права и retention.

• [ ] Policy находится в Git и прошла review.

• [ ] Для каждой группы сохранён n.

• [ ] Малые группы подавляются.

• [ ] Ограничение fairness сформулировано явно.

• [ ] Threat model содержит residual risk.

• [ ] Секреты и raw features отсутствуют в evidence/логах.

• [ ] License record основан на официальном источнике.

• [ ] Тесты и CI успешны.

• [ ] У каждого участника отдельный output и evidence card.

• [ ] Итог отмечен tag `lr14-v1`.

32. Связь с ЛР15

В ЛР15 release constraints, SLO, security controls и допустимое назначение станут входами для нагрузочного теста и решения о масштабировании. Производительность без ограничений риска не является готовностью к выпуску.

33. Официальные источники

• NIST AI RMF: https://www.nist.gov/itl/ai-risk-management-framework

• NIST AI RMF Core: https://airc.nist.gov/airmf-resources/airmf/5-sec-core/

• Model Card Toolkit repository (архивирован): https://github.com/tensorflow/model-card-toolkit

• GitHub secret security: https://docs.github.com/en/code-security/concepts/secret-security

• scikit-learn model evaluation: https://scikit-learn.org/stable/modules/model_evaluation.html